

# T1.4.C aprobado · Guardrails para T1.4.D

Aprobación formal de T1.4.C + reglas vinculantes para T1.4.D

Owner: Celestino · 2026-05-03 · Branch `pr/t1.4.c-usuario-resumen` @ commit `9030bec`

**T1.4.C aprobado por Dona Control para merge.** Branch limpia y sincronizada con remoto. PR listo para mergear vía GitHub UI. Guardrails T1.4.D persistidas en memoria de Claude para sesiones futuras.

## 1. Estado del PR T1.4.C

| Item                                                                   | Estado |
|------------------------------------------------------------------------|--------|
| Endpoint POST <code>/internal/usuario-resumen</code> creado            | ✓      |
| Auth via HMAC con <code>INTERNAL_BRIDGE_SECRET</code>                  | ✓      |
| Read-only (verificado con test antes/después)                          | ✓      |
| No toca producción (sin deploy, sin merge)                             | ✓      |
| 21 tests nuevos verdes                                                 | ✓      |
| Suite completa: 575 passed ( $\Delta +21$ vs baseline)                 | ✓      |
| No requiere env var nueva (reusa <code>INTERNAL_BRIDGE_SECRET</code> ) | ✓      |
| Aprobado por Dona Control                                              | ✓      |

**PR para mergear:** <https://github.com/celestinojbm/Dona-agent/compare/main...pr/t1.4.c-usuario-resumen>

## 2. Guardrails capturadas para T1.4.D

Estas reglas vienen de la revisión del owner sobre T1.4.C. Cuando se inicie T1.4.D, **deben respetarse desde el primer commit**, no como follow-up.

### 2.1 Identificador de usuario sólo desde la sesión server-side

**Regla:** `landing/app/api/dashboard-data/route.ts` (T1.4.D) **NO** debe aceptar `subscription_id` desde el cliente/browser. El identificador debe leerse **únicamente** desde la sesión server-side de NextAuth (ej. `session.subscriptionId`).

**Patrón obligatorio:**

```
import { auth } from "@/auth";

export async function GET() {
  const session = await auth();
  if (!session) return new Response(null, { status: 401 });

  const subscriptionId = (session as any).subscriptionId;
  if (!subscriptionId) return new Response(null, { status: 403 });

  // ... POST a backend con HMAC, usando subscriptionId
  //   tomado de session, NO del request del cliente
}
```

**Razón:** El HMAC protege la comunicación landing → backend contra manipulación en tránsito, pero NO impide que un usuario autenticado intente consultar la suscripción de OTRO usuario enviando un `subscription_id` ajeno desde el navegador. Confiar en `session.*` server-side es la única forma de garantizar que el dato pedido corresponde al usuario logueado.

**Aplica también a:**

- `/api/cancel-subscription` (ya cumple — usa `session.subscriptionId`).
- Cualquier futuro proxy del landing al backend (T1.4.E, T1.4.F).
- Cualquier ruta que mande request firmado al `/internal/*` del backend.

## 2.2 No loguear `subscription_id` completo en producción

**Regla:** En producción, los identificadores Stripe (`sub_xxx`, `cus_xxx`, `in_xxx`) se truncan o redactan en logs. No son secretos crudos pero correlacionan trivialmente con un usuario específico. **No es blocker para T1.4.C.** Aplica a código nuevo de T1.4.D en adelante.

**Patrones aceptables:**

```
# Backend (Python):
sub_short = sub_id[:8] + "..." + sub_id[-4:] \
    if len(sub_id) > 12 else sub_id
logger.info(f"[INTERNAL] usuario-resumen para sub={sub_short}")

// Landing (TypeScript):
const subShort = subId.length > 12
  ? `${subId.slice(0, 8)}...${subId.slice(-4)}`
  : subId;
console.log(`[BRIDGE] dashboard-data sub=${subShort}`);
```

Código existente de T1.3.\* y T1.4.C ya quedó como está. No requiere refactor inmediato.

### 3. Diseño tentativo de T1.4.D (sin implementar)

#### Archivo nuevo

landing/app/api/dashboard-data/route.ts — handler GET.

#### Flujo server-side

- 1. const session = await auth();
- 2. Si no hay sesión → 401 unauthenticated.
- 3. Tomar subscriptionId de session.subscriptionId. **NUNCA** del request. Si no está → 403 no\_subscription.
- 4. Llamar al backend en paralelo a Stripe SDK:
  - **Backend:** POST /internal/usuario-resumen con HMAC reusando helper de T1.3.E (extender con fetchUsuarioResumen).
  - **Stripe SDK:** subscriptions.retrieve para current\_period\_end y cancel\_at\_period\_end.
- 5. Mergear: backend JSON + Stripe data + session.user.email.
- 6. Retornar al cliente.

#### Manejo de errores del backend

| Backend respondió | Acción del landing                                     |
|-------------------|--------------------------------------------------------|
| 401               | Log 'secret desincronizado' + 502 al cliente           |
| 404               | 404 al cliente con mensaje 'suscripción no encontrada' |
| 500               | 502 al cliente, log para alerta                        |
| timeout           | 504 al cliente                                         |
| 200 OK            | merge con Stripe data + 200 al cliente                 |

#### Validación a correr en T1.4.D

- npx tsc --noEmit — 0 errores.
- npm run lint — sin nuevos.
- npm run build — pasa, ruta nueva registrada.
- Smoke manual: con sesión válida → 200 con datos.
- Smoke negativo: sesión sin subscriptionId → 401/403.

#### Lo que NO hacer en T1.4.D

- No modificar el endpoint backend (T1.4.C aprobado).
- No exponer INTERNAL\_BRIDGE\_SECRET ni STRIPE\_SECRET\_KEY al cliente.
- No aceptar subscription\_id (ni cualquier otro id de usuario) del request del browser.
- No tocar UI del dashboard (T1.4.E).
- No tocar cancelación (T1.4.F).

## 4. Persistencia en memoria de Claude

Las dos guardrails se guardaron en el sistema de memoria de Claude para que estén disponibles en futuras sesiones aunque cambie el contexto:

```
memory/feedback_landing_proxy_identifiers.md
memory/feedback_no_log_full_subscription_id.md
```

Indexadas en *MEMORY.md*. Aplican a cualquier proxy nuevo del landing al backend, no solo T1.4.D.

## 5. Pendientes housekeeping (acumulados desde T1.4.A)

Tras mergear T1.4.C quedarán **10 archivos untracked** en docs/auditorias/ y docs/scripts/ (reportes T1.4.A, T1.4.B, T1.4.C y este mismo doc). Recomendación: housekeeping al cierre de T1.4 (después de mergear T1.4.D / E / F), siguiendo el patrón de *pr/post-t1.3-housekeeping*.

## 6. Próximos pasos del owner

- 1. **Mergear T1.4.C** vía **GitHub** UI:  
<https://github.com/celestinojbm/Dona-agent/compare/main...pr/t1.4.c-usuario-resumen>
- 2. Render redespiega automáticamente — el endpoint queda **desplegado pero sin tráfico** hasta T1.4.D.
- 3. Cuando estés listo, autorizar T1.4.D — Claude implementará respetando las dos guardrails desde el primer commit.

Documento generado el 2026-05-03 por Claude Code (Opus 4.7) en sesión con el owner. Captura aprobación de T1.4.C y guardrails para T1.4.D. No incluye cambios de código ni operaciones de despliegue.